

AFTERNOON WORKSHOP

Risk Management & Third-Party Vendor Risk

An Applied Workshop

Workshop Overview

This afternoon, you'll apply everything from this morning's two lessons - Risk Management Fundamentals and Third-Party Risk and Vendor Management - to a realistic company scenario. You'll assess internal security risks, evaluate a third-party vendor, and deliver recommendations the way a real security team would.

Your instructor will assign your group to Track A (Harborview Logistics) or Track B (Meridian Health Partners). Both tracks follow the same three-part structure and are graded against the same rubric - only the company and scenario details differ. Complete only your assigned track.

What You'll Produce

- A completed Risk Register identifying, analyzing, evaluating, and treating at least 6 risks
- A Vendor Risk Evaluation Worksheet recommending whether to approve, conditionally approve, or reject a third-party vendor
- A one-page Executive Summary Memo to leadership synthesizing your top findings

Suggested Group Roles

You'll assume the following roles.

Role	Focus
Risk Analyst	Leads Part 1 — identifying, analyzing, and prioritizing internal risks
Vendor Evaluator	Leads Part 2 — reviewing the vendor questionnaire and drafting contract terms
Compliance & Monitoring Lead	Designs the ongoing monitoring plan and checks work against the rubric

Submission Checklist

- ☐ Risk Register with at least 6 risks, fully rated and treated
- ☐ Vendor Risk Evaluation Worksheet with a clear decision and at least 4 contractual protections
- ☐ Ongoing monitoring plan for the vendor
- ☐ One-page Executive Summary Memo

NOTE

There is often more than one defensible answer in this workshop, especially for risk ratings and vendor decisions. What matters most is that you can justify your reasoning using the concepts from today's lessons.

Meridian Health Partners

Telehealth provider · 260 employees · 4-state service area · 2 clinic locations

Company Snapshot

Meridian Health Partners is a telehealth provider serving patients across four states through video visits, a patient portal, and in-person intake at two clinic locations. The organization uses CarePath Cloud for electronic health record (EHR) hosting, ClaimLogic for insurance billing and claims processing, and TeleConnect Live to host video visits.

Meridian also contracts with QuickFix IT Support, a third-party helpdesk vendor whose technicians remotely manage and maintain clinician laptops, including software installs, patching, and troubleshooting. QuickFix's contract renewal review is underway.

Internal Audit & Interview Notes

These notes are drawn from a recent internal walkthrough and staff interviews. Not every note describes a risk in the same way — part of your job is to translate each one into a clear risk statement.

- *"Several clinicians access the patient portal from personal phones and laptops; there's no mobile device management (MDM) enrollment requirement."*
- *"Password policy requires 8 characters, but multi-factor authentication is optional — only about a third of staff have turned it on."*
- *"The clinic's written incident response plan was last updated two years ago and has never been tested with a tabletop exercise."*
- *"Paper intake forms containing patient information are stored in an unlocked file room behind the reception desk; sign-in and access aren't logged."*
- *"ClaimLogic, the billing vendor, disclosed a minor security incident involving an internal phishing attempt last year; Meridian never followed up to confirm remediation."*
- *"QuickFix IT Support technicians have standing local administrator rights on every clinician laptop, and that access isn't reviewed or time-limited."*
- *"A staff newsletter article noted that healthcare has had the highest average data breach cost of any industry for multiple years running."*

VENDOR IN FOCUS

QuickFix IT Support — remote IT helpdesk contractor. QuickFix has supported Meridian for 18 months, providing software installs, patching, and troubleshooting for clinician laptops. Their contract renewal review is underway.

Vendor Security Questionnaire Responses — QuickFix IT Support

As part of the renewal review, your team requested that the vendor complete a standard security questionnaire. Their responses are below.

Q: Do you require MFA for technicians accessing client devices remotely?

A: "Our team shares a support login for our remote access tool since it's faster than each tech logging in separately."

Q: Do you hold any independent security certifications?

A: "No, we're a small local IT shop — certifications haven't come up before."

Q: What is your incident response process?

A: "If something looks wrong, whoever's on shift handles it and lets the client know if needed."

Q: How is your access to client devices scoped?

A: "We keep admin rights on all client laptops permanently so we don't have to ask for access every time we get a ticket."

Q: What is your policy for staff background checks and data handling training?

A: "We haven't formalized that, but our techs are trustworthy — we know them personally."

Part 1 — Risk Assessment & Risk Register

Using the internal audit & interview notes above, complete a full risk assessment for Meridian Health Partners.

Step 1: Identify

List at least 6 distinct risks. For each, write a one-sentence risk statement in your own words — don't just copy the note verbatim.

Step 2: Analyze

For each risk, rate Likelihood (Low / Medium / High) and Impact (Low / Medium / High). Be ready to justify each rating.

Step 3: Evaluate

Based on your Likelihood × Impact rating, assign an overall Risk Level: Critical, Elevated, or Tolerable.

Step 4: Treat

Recommend a response strategy for each risk — Accept, Avoid, Transfer, or Mitigate — and assign an owner (the role or team responsible for acting on it).

Deliverable: Risk Register

#	Risk Description	Likelihood	Impact	Risk Level	Treatment Strategy	Owner
1						
2						
3						
4						
5						
6						

Part 2 — Vendor Risk Evaluation

Now turn back to the vendor questionnaire responses from QuickFix IT Support earlier in this packet.

Step 1: Spot the Red Flags

Identify at least 4 specific red flags in the questionnaire responses. List them below.

1. _____
2. _____
3. _____
4. _____

Step 2: Decision

Would your group Approve, Conditionally Approve, or Reject renewing access for QuickFix IT Support? Circle one and justify your decision in 2–3 sentences.

Decision: **Approve** **Conditionally Approve** **Reject**

Justification: _____

Step 3: Contractual Protections

If your group conditionally approved (or approved with conditions), list at least 4 specific contractual protections Meridian Health Partners should require before renewal. For each, briefly note what it would require of the vendor.

Protection	What It Requires of the Vendor

Step 4: Ongoing Monitoring Plan

Propose how your group would monitor this vendor going forward. Address all three:

1. Review cadence — how often will you formally reassess this vendor?
2. What you'll monitor — e.g., access logs, security ratings, updated attestations
3. Access scope changes — what, if anything, should change about the vendor's current access?

Monitoring Plan: _____

Part 3 — Executive Summary Memo

Synthesize your findings into a short memo leadership could actually act on. Keep it to about half a page — 4–6 sentences. Include:

- Your top 3 priority risks, drawn from both the internal environment and the vendor relationship
- Your overall recommendation on the vendor relationship
- One specific resource or budget request needed to address your highest-priority item

To:	<i>Chief Operating Officer, Meridian Health Partners</i>
From:	<i>[Your Name]</i>
Date:	<i>[Today's Date]</i>
Re:	<i>Risk & Vendor Review — Meridian Health Partners</i>

Scoring Rubric — 100 – Points (Scale 4)

Use this rubric for both tracks. Scores reward completeness and sound reasoning, not a single "correct" answer.

Category	Points	Exemplary	Developing / Incomplete
Risk Identification & Analysis (Part 1, Steps 1–2)	20	At least 6 distinct, well-stated risks; Likelihood and Impact ratings are reasonable and justified	Fewer than 6 risks, vague risk statements, or ratings given with no justification
Risk Register Quality & Treatment (Part 1, Steps 3–4)	20	Risk Level follows logically from ratings; treatment strategy matches the risk and cites the	Risk Level doesn't match ratings; treatment strategy is missing, mismatched, or the same strategy

Category	Points	Exemplary	Developing / Incomplete
		correct strategy type; owners are appropriate	used for everything without reasoning
Vendor Red-Flag Identification (Part 2, Step 1)	15	At least 4 specific, accurate red flags tied directly to questionnaire language	Fewer than 4, or flags are generic and not tied to the vendor's actual responses
Vendor Decision & Contractual Protections (Part 2, Steps 2–3)	20	Decision is clearly justified and consistent with the red flags found; at least 4 specific, relevant contractual protections are proposed	Decision contradicts the red flags identified; fewer than 4 protections, or protections are vague ("be more secure")
Ongoing Monitoring Plan (Part 2, Step 4)	10	Addresses cadence, what's monitored, and an access-scope change; plan is specific to this vendor	Missing one or more of the three elements; plan is generic and could apply to any vendor
Executive Summary Memo (Part 3)	10	Concise (4–6 sentences), names top 3 risks across both internal and vendor findings, gives a clear recommendation and a specific resource ask	Missing one of the required elements, overlong, or too vague to act on
Completeness	5	Assignment fully completed and submitted on time	Incomplete sections; no evidence of attempted completion.
Total	100 - Scale (0-4) 0-24=0, 25-59=2, 60-74=3, 75 > = 4		

